

1. El Objetivo: protocolos de señalización , la inteligencia de las telecomunicaciones Red Menshen busca **acceso persistente a largo plazo** para la recolección de inteligencia geopolítica.

Protocolos Críticos: Se enfocan en protocolos de señalización como **SS7, Diameter y SCTP**. Estos gestionan la movilidad, identidad y conectividad global de los suscriptores. lo que los hace excepcionalmente valiosos para la recopilación de inteligencia, mucho más allá de lo que permite una filtración de datos convencional..

Impacto: Al controlar estos nodos, pueden rastrear ubicaciones, interceptar metadatos de comunicación y vigilar objetivos gubernamentales o diplomáticos de alto valor. Las redes de telecomunicaciones transportan comunicaciones gubernamentales, autentican identidades de suscriptores, coordinan industrias críticas y procesan flujos de señalización a través de las fronteras nacionales.

Hackers del grupo ATP Chino Red Menshen. instalan puertas traseras BPFdoor sigilosas en redes de telecomunicaciones para obtener y disponer de acceso a largo plazo, con el malware BPFDoor subsistema Berkeley Packet Filter (BPF)

El acceso persistente dentro del núcleo de un operador telecomunicación puede exponer identificadores de suscriptores, eventos de movilidad, intercambios de autenticación y metadatos de comunicación, permitiendo el seguimiento a gran escala de objetivos geopolíticos de alto valor.

Red Menshen ha atacado específicamente a proveedores de telecomunicaciones en Corea del Sur, Hong Kong, Myanmar, Malasia, Egipto y Oriente Medio, con un riesgo colateral que se extiende a las redes gubernamentales que dependen de esos operadores.

2. El Malware: BPFdoor, una puerta trasera (backdoor) para Linux sigilosa que opera a nivel de **kernel**.

BPFdoor: Una puerta trasera a nivel de kernel, imita procesos legítimos en servidores bare-metal HPE ProLiant, <https://www.hpe.com/es/es/hpe-proliant-compute.html/> suplantando específicamente a hpsmlited .. también emplea un canal de control basado en ICMP, donde los servidores comprometidos se transmiten comandos entre sí utilizando paquetes ICMP manipulados incrustados con el valor 0xFFFFFFFF como una señal terminal de "no reenviar", permitiendo la propagación lateral sin tráfico C2 estándar.

Una investigación realizada por Rapid7 Labs ha expuesto una sofisticada campaña de espionaje patrocinada por el estado Chino, llevada a cabo por **Red Menshen**..
<https://www.rapid7.com/blog/post/tr-bpfdoor-telecom-networks-sleeper-cells-threat-research-report/>
Publicados el 26 de marzo de 2026, los hallazgos revelan persistencia y posicionamiento a largo plazo dentro de las redes troncales que sostienen las comunicaciones nacionales e internacionales.

eBPF significa Filtro de Paquetes Berkeley Extendido. eBPF permite a los usuarios instalar código de forma dinámica que se ejecuta en el kernel Linux, pero que se gestiona desde el espacio de usuario. Una especie de híbrido entre las aplicaciones de espacio de usuario y los módulos del kernel de Linux. BPFDoor utiliza filtros de socket para permitir comunicaciones sigilosas. Puede recibir comandos en cualquier puerto del sistema ya que el programa eBPF que utiliza ve todo el tráfico entrante.

<https://github.com/hackingyseguridad/APT41/blob/main/ebpf.md>

Filtros de paquetes de Berkeley (BPF), ejemplo, llamadas también expresiones:

Abuso de BPF: BPF es una tecnología del kernel que permite ejecutar código de forma segura en respuesta a eventos de red. Tradicionalmente se usa para herramientas como tcpdump, Wireshark, Tshark,...; **BPFdoor** abusa de esta funcionalidad al inyectar un filtro BPF personalizado directamente en el kernel. Este filtro inspecciona silenciosamente todo el tráfico entrante sin necesidad de:

Abrir puertos de escucha (no aparece en netstat o ss).

Generar tráfico de comando y control (C2) visible.

Dejar procesos en espacio de usuario que puedan ser detectados fácilmente.

Utiliza esta tecnología del kernel para inspeccionar el tráfico de red sin abrir puertos de escucha. Esto significa que herramientas como `netstat`, `ss` o `nmap` no detectan nada inusual;

el sistema parece "limpio".

****El "Paquete Mágico":**** El implante permanece dormido hasta que recibe un paquete especialmente diseñado con una secuencia de bytes específica (un "paquete mágico"). Al detectarlo, el malware activa una terminal de comandos (*shell*) para el atacante.

****Evasión de Firewall:**** Como el filtro BPF actúa a un nivel muy bajo en el núcleo, puede ver y procesar el paquete antes de que el firewall local del sistema operativo tenga oportunidad de bloquearlo.

eBPF: (Extended Berkeley Packet Filter) es una tecnología en el kernel de Linux que permite ejecutar programas personalizados dentro del núcleo del sistema operativo sin necesidad de cambiar el código fuente ni reiniciar. Es como añadir "sensores" inteligentes que pueden observar y actuar sobre todo lo que ocurre en el motor del ordenador de forma segura y extremadamente rápida. El malware avanzado utiliza eBPF para una técnica llamada manipulación de visibilidad, actuando como un filtro invisible entre el sistema y el usuario: Intercepción (Hooking): El malware se "engancha" a las funciones del kernel que gestionan la red o el sistema de archivos. Filtrado Selectivo: Cuando una herramienta de seguridad (como un antivirus o un monitor de red) pide datos, el programa eBPF intercepta esa información antes de que salga del núcleo. Alteración de Datos: El programa busca cualquier rastro de su propia actividad (una dirección IP específica, un archivo o un proceso) y lo elimina de los resultados en tiempo real. 3. Ejemplo de funcionamiento: Acción Intervención del Malware eBPF Resultado para el Usuario Tráfico de Red Identifica paquetes de la IP del atacante y los oculta. Los logs de red parecen limpios. Listar Archivos Borra el nombre del archivo malicioso de la lista. La carpeta parece no tener nada sospechoso. Monitor de Procesos Oculta el ID del proceso del malware. El malware no aparece en el "Administrador de Tareas". 4. ¿Por qué es tan peligroso? Dado que estos programas corren dentro del núcleo (kernel), tienen una autoridad superior a la mayoría de las herramientas de seguridad tradicionales. Si el malware consigue cargar un programa eBPF con privilegios de administrador, se vuelve virtualmente invisible, ya que "engaña" a las herramientas de observación desde la raíz del sistema. Los atacantes suelen explotar vulnerabilidades de escalada de privilegios para obtener acceso de nivel root, ya que el kernel está protegido contra usuarios comunes. Una vez dentro, utilizan las siguientes técnicas para manipular el MPF (Multi-Processor Floating pointer) o filtrar rutas:

Técnicas de Infiltración y Modificación: Rootkits de Kernel (LKM): Cargan "Linux Kernel Modules" maliciosos que interceptan llamadas al sistema (syscall hooking). Esto les permite alterar lo que el sistema operativo "ve", ocultando archivos o procesos antes de que lleguen al espacio de usuario. Manipulación de /proc y /sys: Si tienen permisos de escritura, modifican estos sistemas de archivos virtuales para cambiar parámetros de red y memoria en tiempo real sin reiniciar. Direct Kernel Object Manipulation (DKOM): Acceden directamente a la memoria /dev/mem para modificar estructuras de datos del kernel, permitiendo saltarse filtros de seguridad o esconder rutas de red. eBPF Malicioso: Utilizan herramientas modernas del kernel para inyectar programas que filtran o modifican el tráfico de red y los datos del sistema de manera casi invisible.

El "Secuestro" en la Capa de Enlace (BPF clásico) Este es el método original de BPFDoor. No usa eBPF, sino el BPF clásico, pero el principio es el mismo .

Cómo funciona: El malware crea un socket AF_PACKET y adjunta un filtro BPF personalizado. Este filtro actúa como un portero: inspecciona cada paquete que llega a la interfaz de red en busca de una "palabra mágica" (magic packet) en el payload (por ejemplo, los bytes 0x7255 en UDP o 0x5293 en TCP) .

La Evasión: El filtro está programado para descartar (dropear) silenciosamente los paquetes que no le interesan. Como tcpdump y Wireshark también capturan paquetes en este mismo nivel (AF_PACKET), el filtro malicioso puede ejecutarse antes y ocultar el tráfico que no quiere que sea visto. Es como si el malware le quitara los paquetes de la bandeja de entrada a las herramientas de monitoreo .

La Intercepción Ultra-Temprana (eBPF con XDP) Esta es una técnica más nueva y potente, utilizada por rootkits como LinkPro y mencionada en investigaciones sobre BPFDoor avanzado .

Cómo funciona: Utiliza eBPF en el modo XDP (eXpress Data Path). El programa XDP se ejecuta dentro del driver de la tarjeta de red, incluso antes de que el paquete entre al kernel de Linux .

La Evasión: En este punto, tcpdump y Wireshark (que dependen de la pila de red del kernel) ni siquiera han visto el paquete. El rootkit XDP puede analizar, redirigir o dropear el paquete sin dejar absolutamente ningún rastro para las herramientas de monitoreo convencionales. Es la máxima expresión de invisibilidad .

Más Allá de la Red: Ocultando su Propia Existencia La capacidad de evasión de estos malware va más allá de ocultar el tráfico. También se ocultan a sí mismos para que no puedas encontrar el origen

del problema:

Ocultación de Procesos y Archivos: Rootkits como LinkPro y Singularity utilizan hooks eBPF (en sistemas de archivos como getdents) para interceptar llamadas al sistema. Cuando ejecutas `ps` o `ls` para buscar el malware, el rootkit filtra los resultados y elimina su propio nombre y PID de la lista, haciéndose invisible .

Auto-ocultamiento de los Programas eBPF: Lo más sofisticado es que pueden ocultarse a sí mismos de herramientas de diagnóstico. Por ejemplo, LinkPro hooke la llamada al sistema `sys_bpf`. Esto significa que si ejecutas `bpftool prog list` (la herramienta estándar para ver programas eBPF), el rootkit intercepta la solicitud y elimina su propio programa de la lista .

****cómo actúa el implante malicioso:****

-Victim Linux Host (Host Linux Víctima): El atacante ha instalado un "BPF Implant".

-Magic Packet (Paquete Mágico): El Attacker/Controller (Atacante/Controlador) envía un paquete especial diseñado para activar el malware.

-BPF Filter (Magic Packet Pattern): El malware utiliza un filtro BPF que busca específicamente el patrón de ese "paquete mágico". Como este filtrado ocurre a un nivel muy bajo en el núcleo (Kernel), puede ver el paquete antes de que cualquier firewall local lo bloquee.

-Activate Bind Shell or Reverse Shell: Una vez detectado el paquete, el implante activa una terminal de comandos (Shell) para que el atacante tome el control.

****BPFdoor: Una puerta trampilla a nivel del kernel****

BPFdoor usa principalmente BPF, mientras que variantes del malware más modernas como Symbiote (Fortinet) usan eBPF para mayor complejidad.

****Paquete magico,**** a diferencia del malware convencional, BPFdoor no abre puertos de escucha ni genera balizamiento visible de comando y control. En su lugar, ****instala un filtro BPF personalizado dentro del kernel que inspecciona silenciosamente el tráfico entrante, activándose solo cuando recibe un "paquete mágico"*** especialmente diseñado que contiene una secuencia de bytes predefinida. Herramientas como netstat, ss o nmap no muestran nada inusual; el sistema parece completamente limpio.

3. otras técnicas avanzadas de sigilo y camuflaje

El informe de Rapid7 Labs destaca una evolución en las tácticas del grupo:

****Ocultamiento en HTTPS:**** Las versiones más nuevas esconden sus comandos dentro de tráfico HTTPS legítimo. Aprovechan puntos de terminación SSL (como balanceadores de carga) para activarse justo después de que el tráfico es descifrado en la red interna.

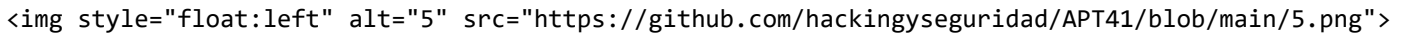
****Regla Mágica (Offset Fijo):**** Utilizan un marcador ("9999") en desplazamientos fijos de 26 o 40 bytes para asegurar que el comando sobreviva a la reescritura de cabeceras de los proxies.

****Propagación Lateral vía ICMP:**** Los servidores ya comprometidos se comunican entre sí mediante paquetes ICMP (pings) manipulados con el valor `0xFFFFFFFF`. Esto permite saltar entre zonas de red (de la DMZ al Core) sin generar tráfico de Comando y Control (C2) detectable.

Nueva variante más sigilosa: Los comandos de activación ya no se envían como ****"paquetes mágicos"*** fácilmente detectables, sino que se ocultan dentro del tráfico HTTPS legítimo, aprovechando los puntos de terminación SSL (como balanceadores de carga) para activarse tras el descifrado.

Rapid7 Labs identificó una variante de BPFdoor no documentada anteriormente que mejora significativamente sus capacidades de sigilo. En lugar de depender de un paquete mágico detectable, la variante actualizada ahora oculta los desencadenantes de comandos dentro del tráfico HTTPS legítimo, explotando puntos de terminación SSL como balanceadores de carga y proxies inversos para entregar comandos de activación después del descifrado en la zona de red interna.

La variante también emplea un canal de control basado en ICMP, donde los servidores comprometidos se transmiten comandos entre sí utilizando paquetes ICMP manipulados incrustados con el valor `0xFFFFFFFF` como una señal terminal de "no reenviar", permitiendo la propagación lateral sin tráfico C2 estándar.



Túnel ICMP para acceder a un núcleo aislado de 3 capas:

El atacante activa un shell en el Nodo B (servidor interno, capa 2) usando un proxy inverso.

El Nodo B prepara un listener Netcat en el puerto 9000.

Un controlador ordena al Nodo B que use el Nodo C (núcleo aislado, capa 3) como siguiente salto.

El Nodo B, mediante un implante BPFdoor, redirige la orden por ICMP al Nodo C.

El Nodo C devuelve un shell al Nodo B, dando acceso al atacante.

Resumen: Se salta el aislamiento del núcleo (Nodo C) usando ICMP como transporte, con el Nodo B como puente.

Comunicación lateral con ICMP: ****Los servidores comprometidos pueden comunicarse entre sí usando paquetes ICMP**** personalizados con un valor específico (0xFFFFFFFF), permitiendo la propagación lateral sin generar tráfico de comando y control tradicional.

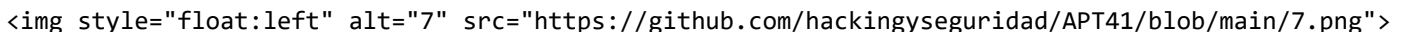
protocolo ICMP (Internet Control Message Protocol) generalmente utilizado para diagnósticos simples como ping para transportar datos maliciosos y comandos. El malware abre un "raw socket" que le permite ver todos los paquetes que llegan a la interfaz de red antes de que el firewall local del sistema operativo los procese. Puede responder a paquetes ICMP manipulados incluso si el firewall está configurado para bloquear todo el tráfico entrante, ya que el filtro BPF "secuestra" el paquete antes de que el kernel lo descarte

Flujo de Ataque: Del L1 al Núcleo Aislado (L3) El ataque se divide en capas para alcanzar el HSS (Home Subscriber Server) en el núcleo aislado, un componente crítico en redes de telecomunicaciones. Paso Acción Descripción Técnica 1 & 2 Acceso Inicial El atacante toma control del Nodo B (Servidor Interno) a través de un Proxy inverso (Nodo A). Se prepara un listener (nc -lvp 9000) para recibir la shell. 3 & 4 Activación del Túnel El controlador envía una señal al Nodo B. El implante intercepta esta señal y genera un ICMP Echo Request (Ping) hacia el Nodo C. 5 Propagación Lateral El Nodo C (también infectado) recibe el paquete ICMP. Al detectar la firma maliciosa en el payload, ejecuta una shell y la "devuelve" al Nodo B, permitiendo al atacante operar en la capa L3.

El valor hexadecimal 0xFFFFFFFF actúa como un carácter de escape o terminación. Indica al implante que el comando ha llegado a su destino final y no debe seguir saltando a otros nodos. Esto evita bucles infinitos y reduce el "ruido" en la red, haciendo que el tráfico parezca una serie de pings normales y no un escaneo de red o una exfiltración masiva. 0xFFFFFFFF. Sería bueno aclarar que esto se inserta en el Payload (datos) del paquete ICMP Echo Request, no en la cabecera estándar, lo que lo hace pasar desapercibido para firewalls que solo miran cabeceras.

ICMP esta permitido incluso entre redes, para monitoreo de disponibilidad, considerándolo de bajo riesgo; "salta" de la zona desmilitarizada (DMZ) al núcleo de la red (Core) usando los mismos canales que usan las herramientas de red legítimas.

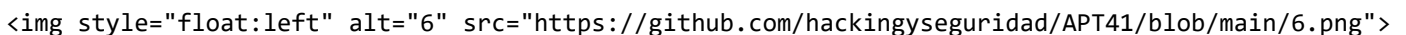
```
tshark -i eth0 -Y "icmp.type == 8" -T fields -e data | grep "ffffffff"
```



4. Suplantación de Infraestructura

Algunas muestras de BPFdoor imitan procesos legítimos en servidores HPE ProLiant (software de HPÉ para monitorizar procesos), específicamente suplantando a ****hpsmlited****, un proceso perteneciente al Servicio de Gestión sin Agente de HPE, para meterse en entornos de hardware de telecomunicaciones que ejecutan cargas de trabajo de núcleo 4G/5G.

Otras muestras suplantán a componentes de ****Docker y containerd****, apuntando a funciones de núcleo 5G alojadas en Kubernetes como AMF, SMF y UDM.



Para evitar ser detectados por administradores de sistemas, el malware imita procesos legítimos:

- * En servidores ****HPE ProLiant****, se hace pasar por el proceso `hpsmlited` (un servicio de gestión de hardware).
- * En entornos de nube, suplanta componentes de ****Docker, containerd y Kubernetes**** (AMF, SMF,

UDM), apuntando específicamente a las funciones del núcleo de las redes 5G.

5. Acceso inicial

****Acceso Inicial:**** Suelen entrar explotando vulnerabilidades en dispositivos perimetrales como VPNs Ivanti, firewalls Fortinet, routers Cisco/Juniper y servidores VMware ESXi.

****Defensa:**** Se recomienda a los administradores de red ampliar la visibilidad hacia operaciones a nivel de kernel y monitorear el tráfico anómalo en protocolos SCTP e ICMP, donde el malware suele ocultar sus movimientos.

Rapid7 ha publicado un script de detección gratuito y recomienda a los defensores ampliar la visibilidad hacia operaciones a nivel del kernel y el monitoreo de tráfico SCTP, áreas donde la mayoría de las organizaciones carecen de cobertura.

****El acceso inicial**** apunta a infraestructura perimetral: VPNs Ivanti Connect Secure, dispositivos de red Cisco y Juniper, firewalls Fortinet y hosts VMware ESXi. Las herramientas posteriores a la explotación incluyen CrossC2, TinyShell, escáneres de fuerza bruta SSH y registradores de teclas ELF personalizados con listas de credenciales conscientes de telecomunicaciones que hacen referencia a términos como "imsi".

Rapid7 ha coordinado con los CERT nacionales y socios gubernamentales para notificar a las organizaciones afectadas. La firma lanzó un script de escaneo gratuito y de código abierto capaz de detectar variantes tanto antiguas como nuevas de BPFdoor para ayudar a las organizaciones en la validación rápida de exposición.

**** Recomendaciones:****

Ampliar la visibilidad hacia operaciones a nivel de kernel.

Monitorear tráfico SCTP y anomalías en paquetes ICMP (pings con payloads inusuales).

Utilizar scripts de detección especializados para BPFdoor.

**** Detección: Cómo Identificarlo****

Dado que estas amenazas operan a nivel de kernel, la defensa debe ser igualmente rigurosa. Aquí tienes un plan de acción basado en las investigaciones:

Monitoreo de Comportamiento, no de Paquetes: Depende de herramientas de Detección y Respuesta de Endpoint (EDR) que analicen el comportamiento del sistema, como Falco. Falco puede detectar eventos sospechosos, como el uso del syscall setsockopt con la opción SO_ATTACH_FILTER, que es una forma común de cargar estos filtros .

Auditoría de Programas eBPF: Revisa periódicamente los programas eBPF cargados con bpftool prog list y compáralos con una línea base de tu sistema. Presta especial atención a programas con nombres aleatorios o inesperados .

Restricción de Capacidades: Limita el uso de eBPF. Asegúrate de que el parámetro del kernel kernel.bpf_enable_unprivileged esté desactivado (=0). Esto evita que usuarios sin privilegios carguen programas eBPF . Para procesos legítimos, usa capacidades de Linux de forma restrictiva.

Monitoreo de Modificaciones del Sistema: Utiliza sistemas de integridad de archivos (FIM) como AIDE o Tripwire para detectar cambios no autorizados en archivos críticos del sistema, ya que algunos rootkits modifican /etc/ld.so.preload para inyectarse .

Mantén el Kernel Actualizado: Las nuevas versiones del kernel incluyen mejoras en el verificador (verifier) de eBPF y parches de seguridad que dificultan la explotación de estas técnicas.

****Medidas Defensivas:****

Firmado de Módulos: Impedir que el kernel cargue módulos que no tengan una firma digital legítima.

Kernel Lockdown: Activar el modo lockdown para restringir el acceso a /dev/mem y otras interfaces críticas incluso para el usuario root.

Auditoría constante: Usar herramientas como auditd para monitorear cambios inesperados en los parámetros del sistema.

Monitoreo de Comportamiento, no de Paquetes: Depende de herramientas de Detección y Respuesta de Endpoint (EDR) que analicen el comportamiento del sistema, como Falco. Falco puede detectar eventos sospechosos, como el uso del syscall setsockopt con la opción SO_ATTACH_FILTER, que es una forma común de cargar estos filtros .

Auditoría de Programas eBPF: Revisa periódicamente los programas eBPF cargados con bpftool prog list y compáralos con una línea base de tu sistema. Presta especial atención a programas con nombres aleatorios o inesperados .

Restricción de Capacidades: Limita el uso de eBPF. Asegúrate de que el parámetro del kernel kernel.bpf_enable_unprivileged esté desactivado (=0). Esto evita que usuarios sin privilegios carguen programas eBPF . Para procesos legítimos, usa capacidades de Linux de forma restrictiva.

Monitoreo de Modificaciones del Sistema: Utiliza sistemas de integridad de archivos (FIM) como AIDE o Tripwire para detectar cambios no autorizados en archivos críticos del sistema, ya que algunos rootkits modifican /etc/ld.so.preload para inyectarse .

Mantén el Kernel Actualizado: Las nuevas versiones del kernel incluyen mejoras en el verificador (verifier) de eBPF y parches de seguridad que dificultan la explotación de estas técnicas.

Referencias:

Artículo Rapid7:

<https://www.rapid7.com/blog/post/tr-bpfdoor-telecom-networks-sleeper-cells-threat-research-report/>
<https://github.com/rapid7/Rapid7-Labs/tree/main/BPFDoor>
<https://cybersecuritynews.com/bpfdoor-backdoors-telecom-networks/>

Análisis BPFdoor:

<https://medium.com/s2wblog/detailed-analysis-of-bpfdoor-targeting-south-korean-company-328171880a98>
<https://hackers-arise.com/compromising-telecom-systems-deploying-and-detecting-the-bpfdoor-backdoor/>
<https://www.youtube.com/watch?v=5k0Qg-eCPu4>
<https://www.youtube.com/shorts/BTQX9oBn3dw>

Variante Fortinet:

<https://www.cb nuggets.com/blog/certifications/security/fortinet-identifies-new-symbiote-bpfdoor-variants>
<https://www.fortinet.com/blog/threat-research/new-ebpf-filters-for-symbiote-and-bpfdoor-malware>

Detectando variantes BPFdoor:

https://www.trendmicro.com/en_gb/research/23/g/detecting-bpfdoor-backdoor-variants-abusing-bpf-filters.html
<https://suzulabs.com/suzu-labs-blog/bpfdoor-in-telecom-networks-the-fcc-is-securing-the-edge-but-chinas-hackers-are-already-past-it>
<https://blog.g5cybersecurity.com/bpfdoor-detection-removal/>